

Security+ 2.2 · Watering Hole

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 2.2** —
Watering Hole (4:12) · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: A watering hole attack compromises a website that the target group already frequents (e.g., an industry forum, hotel portal) and waits for victims to 'drink' there. The attacker does not directly attack the victim's network; instead, they leverage the natural traffic to deliver a payload.

High-Yield Core Concepts Tested on Exam

- Does not compromise the victim's network — compromises a THIRD-PARTY site the victim trusts
- Waits for the victim to visit: the 'watering hole' is where the target naturally goes
- Often used for strategic, targeted attacks against a specific industry or group

Exam Tips & Classic Scenarios

- 'compromised a website frequented by the target group' = watering hole
- 'attackers infect a site the victim is known to visit' = watering hole

Typical Exam Scenario: Scenario: 'attacker compromises an industry forum to infect its members' = watering hole.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 2.2 — Watering Hole)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **Principle of Least Privilege:** Users and computational entities must be granted only the minimum permissions strictly required to perform designated tasks.
- **Defense-in-Depth (Layered Security):** Application of multiple security controls (technical, administrative, physical) to prevent single-point perimeter compromise.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. An attacker uses RFID to clone employee badges and access restricted areas. What type of physical attack is this?

- A)** Tailgating
- B)** Shoulder surfing
- C)** Credential cloning
- D)** Dumpster diving

2. Compromising a software vendor to reach all of its customers (e.g., SolarWinds):

- A)** Supply chain attack
- B)** Watering hole
- C)** Insider
- D)** Zero-day

3. Corporate scenario (Watering Hole): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.2), an analyst evaluates the following technical requirement: 'Does not compromise the victim's network — compromises a THIRD-PARTY site you trust'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: Does not compromise the victim's network — compromises a THIRD-PARTY site you trust...

4. Corporate scenario (Watering Hole): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.2), an analyst evaluates the following technical requirement: 'Wait for you to come: the 'watering hole' is where the target naturally goes'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: Wait for you to come: the 'watering hole' is where the target naturally goes...
- B)** Temporarily disable audit logs to speed up system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

5. Corporate scenario (Watering Hole): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.2), an analyst evaluates the following technical requirement: 'compromised a website frequented by the target group' = watering hole'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: 'compromised a website frequented by the target group' = watering hole...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

6. Corporate scenario (Watering Hole): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.2), an analyst evaluates the following technical requirement: 'Scenario: 'attacker compromises an industry forum to infect members' = watering hole.'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Scenario: 'attacker compromises an industry forum to infect members' = watering hole...
- D)** Allow shared access among administrators with generic credentials

7. Corporate scenario (Watering Hole): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.2), an analyst evaluates the following technical requirement: 'Does not compromise the victim's network — compromises a THIRD-PARTY site you trust'. What is the best recommendation or classification of applicable control?

- A)** Implement the corresponding solution: Does not compromise the victim's network — compromises a THIRD-PARTY site you trust...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

8. Corporate scenario (Watering Hole): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.2), an analyst evaluates the following technical requirement: 'Wait for you to come: the 'watering hole' is where the target naturally goes'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Wait for you to come: the 'watering hole' is where the target naturally goes...
- D)** Allow shared access among administrators using generic credentials

9. Corporate scenario (Watering Hole): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.2), an analyst evaluates the following technical requirement: 'compromised a website frequented by the target group' = watering hole'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: 'compromised a website frequented by the target group' = watering hole...
- D)** Allow shared access among administrators with generic credentials

10. Corporate scenario (Watering Hole): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.2), an analyst evaluates the following technical requirement: 'Scenario: 'attacker compromises an industry forum to infect members' = watering hole'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: Scenario: 'attacker compromises an industry forum to infect members'...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) C — Credential cloning.

✓ **Why it's correct:** The correct answer is 'Credential cloning'. Credential cloning occurs when an attacker copies the data from an access card (such as RFID badges or proximity cards) to another device, allowing unauthorized access. In the scenario, using RFID to copy the badge signal and replicate it onto a blank card is a classic example of physical credential cloning. CompTIA Security+ covers physical attacks and countermeasures, such as using encrypted cards or mutual authentication to prevent cloning.

✗ **Why the others are wrong:**

- *Tailgating:* Tailgating is the practice of physically following an authorized person through a secure door without using one's own credentials. It does not involve cloning cards or RFID; it is a passive physical intrusion. The option is incorrect because the scenario describes electronic copying of credentials, not entry by proximity.
- *Shoulder surfing:* Shoulder surfing is direct observation over someone's shoulder to obtain information such as passwords or PINs. It does not involve RFID or badge cloning. The option is incorrect because it is a visual observation technique, not electronic duplication.
- *Dumpster diving:* Dumpster diving is searching through trash for discarded information (documents, media) that could be useful to an attacker. It has no relation to RFID or credential cloning. The option is incorrect because it involves recovering discarded data, not intercepting and copying card signals.

2) A — Supply chain attack.

✓ **Why it is correct:** A supply chain attack occurs when an adversary compromises a vendor, partner, or software/hardware component to reach the end customers of that vendor. In the SolarWinds case (2020), attackers compromised the build process of the Orion software, inserting malicious code that was distributed as a legitimate update to thousands of customers, including government agencies. This is the classic example of a supply chain attack, as described in SY0-701 objective 2.2 (supply chain threats) and 2.3 (attack vectors). The question describes exactly this scenario: compromising a software vendor to reach all of its customers.

✗ **Why the others are wrong:**

- *Watering hole:* A watering hole is an attack in which the adversary compromises a legitimate website frequented by a specific group of victims (e.g., an industrial sector site) and inserts malicious code to infect visitors. The goal is to reach users who visit that site, not to compromise a software vendor to distribute malware to all its customers. In a watering hole, the vector is the third-party site visited by victims; in a supply chain attack, the vector is the vendor's own product or update. The question speaks of compromising a software vendor to reach all its customers, which is supply chain, not watering hole.
- *Insider:* An insider threat refers to an individual with authorized access (employee, contractor, partner) who uses that access to cause harm, steal data, or facilitate attacks. The attacker is internal to the organization, not a compromised external vendor. In the SolarWinds case, the attackers were external (APT29) who compromised SolarWinds' supply chain; it is not an insider of SolarWinds or its customers. Therefore, insider does not describe the scenario of compromising a vendor to reach its customers.
- *Zero-day:* A zero-day refers to a vulnerability unknown to the vendor, for which no patch is available. The attack exploits this flaw before it is fixed. Although supply chain attacks may involve zero-days, the concept of zero-day is about the nature of the vulnerability, not about the vector of compromising a vendor to reach customers. In the SolarWinds case, the attack did not rely

exclusively on a zero-day; it involved compromising the build process and distributing a malicious update. The question asks for the name of the attack that compromises a vendor to reach all customers, which is supply chain, not zero-day.

3) D — Implement the corresponding solution: Does not compromise the victim's network — compromises a THIRD-PARTY site you trust....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.2 (Watering Hole): Does not compromise the victim's network — compromises a THIRD-PARTY site you trust. A watering hole attack infects a legitimate website frequently visited by a target group, exploiting trust to deliver malware to visitors.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

4) A — Implement the corresponding solution: Wait for you to come: the 'watering hole' is where the target naturally goes....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.2 (Watering Hole): Wait for you to come: the 'watering hole' is where the target naturally goes.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to speed up system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

5) B — Implement the corresponding solution: 'compromised a website frequented by the target group' = watering hole....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.2 (Watering Hole): 'compromised a website frequented by the target group' = watering hole.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks,

injections, or malware at runtime.

- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

6) C — Implement the corresponding solution: Scenario: 'attacker compromises an industry forum to infect members' = watering hole....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.2 (Watering Hole): Scenario: 'attacker compromises an industry forum to infect members' = watering hole.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

7) A — Implement the corresponding solution: Does not compromise the victim's network — compromises a THIRD-PARTY site you trust....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.2 (Watering Hole): Does not compromise the victim's network — compromises a THIRD-PARTY site you trust.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detect incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

8) C — Implement the corresponding solution: Wait for you to come: the 'watering hole' is where the target naturally goes....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.2 (Watering Hole): Wait for you to come: the 'watering hole' is where the target naturally goes.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks,

injections, or runtime malware.

- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

9) C — Implement the corresponding solution: 'compromised a website frequented by the target group' = watering hole....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.2 (Watering Hole): 'compromised a website frequented by the target group' = watering hole.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.

10) A — Implement the corresponding solution: Scenario: 'attacker compromises an industry forum to infect members'....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.2 (Watering Hole): Scenario: 'attacker compromises an industry forum to infect members' = watering hole. A watering hole attack involves compromising a website frequently visited by a target group, infecting visitors with malware.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.